



CYBERCLASS

Participante: Luis Ramon Reyes Volquez

Facilitador: Kevin Feliz Henríquez

Técnico: Ciberseguridad

Módulo: Seguridad Física

Actividad: Técnicas OSINT para Detección de Sistemas Electrónicos e Información

Descripción: Haremos una investigación sobre un posible delito a una empresa con poca seguridad.

Link de GitHub: <https://github.com/elchecho3000-blip/Ciberseguridad-bootcamp/tree/main/Seguridad%20F%C3%ADsica>

Para analizar este escenario, nos situaremos en una **sala de servidores (Data Center)** de una empresa mediana. Este entorno es el corazón tecnológico de la organización, por lo que un fallo físico (fuego, intrusiones, fallos eléctricos) podría paralizar por completo las operaciones.

A continuación, se presenta un análisis de los principales riesgos físicos en este escenario y los controles recomendados para minimizarlos, clasificados por categorías.

1. Control de Acceso y Gestión de Identidad (Evita el uso de tarjetas compartidas y robadas)

- **Autenticación Multifactor Física (Biometría):** Las tarjetas magnéticas son transferibles y propensas al robo. Se debió implementar un acceso que combinara la tarjeta con un factor biométrico (huella dactilar o reconocimiento facial) para ingresar a las áreas críticas.
- **Principio de Menor Privilegio:** Un empleado temporal de mantenimiento técnico jamás debió tener permisos de acceso a la sala principal de servidores ni a las credenciales de otros trabajadores. Sus accesos debieron limitarse estrictamente a las zonas donde requería trabajar.
- **Política de Cero Tolerancia al Compartir Credenciales:** Implementar auditorías sorpresa y sanciones severas para erradicar el uso negligente de compartir tarjetas de acceso.

2. Seguridad en la Infraestructura y Diseño Físico (Evita la sustracción de equipos)

- **Racks y Gabinetes bajo Llave:** Aunque los atacantes lograron entrar a la sala, los servidores individuales debieron estar atornillados y resguardados dentro de racks de seguridad cerrados con llave física o cerradura electrónica independiente. Esto habría retrasado o impedido que se llevaran los servidores portátiles.
- **Esclusas de Seguridad (Mantrap):** Implementar un sistema de doble puerta en la entrada del centro de datos. La segunda puerta no se abre hasta que la primera se haya cerrado y el personal de seguridad haya verificado la identidad del individuo desde una cabina blindada.

3. Monitoreo y Gestión de Incidentes (Evita el sabotaje de las cámaras)

- **Segregación de Funciones en Mantenimiento:** Un técnico de mantenimiento no debe tener la facultad ni el acceso lógico para apagar el sistema de CCTV. Las funciones de soporte técnico y la administración de la seguridad física deben estar completamente separadas.
- **Protocolo de Ventanas de Mantenimiento:** Cualquier desactivación de cámaras por "mantenimiento preventivo" debió requerir una solicitud formal previa, aprobación digital de la alta gerencia y supervisión física de un guardia durante todo el proceso.
- **Alertas por Pérdida de Señal:** El sistema de CCTV debió emitir una alarma crítica en tiempo real a una central de monitoreo externa (o redundante) en el instante en que las cámaras se desconectaron, levantando sospechas inmediatas en un fin de semana.

4. Protección de los Datos (Mitiga el daño en caso de robo físico)

- **Cifrado de Datos en Reposo (Data at Rest Encryption):** Esta fue la falla más grave que causó el daño irreversible. Si la información en los discos duros de los servidores hubiera estado cifrada utilizando algoritmos robustos (como AES-256), los servidores robados habrían sido completamente inútiles para los atacantes, evitando que la información se vendiera en el mercado negro.
- **Copias de Seguridad Fuera del Sitio (Offsite Backups):** Para evitar la pérdida de contratos por la destrucción o robo de la infraestructura, la empresa debió contar con respaldos automatizados en la nube o en un segundo centro de datos geográficamente distante.

5. Controles Administrativos y de Recursos Humanos (Evita la infiltración)

- **Investigación de Antecedentes (Background Checks):** Proceso riguroso de depuración y validación de antecedentes penales y laborales para todo el personal, incluyendo contratistas y empleados temporales, antes de otorgarles acceso a las instalaciones.
- **Supervisión y Acompañamiento:** El personal temporal o externo debió estar bajo supervisión constante o acompañado por un empleado de planta con confianza comprobada al transitar por áreas de información crítica.

Lo aprendido:

El desastre de DataSecureCorp se pudo haber evitado con cuatro medidas clave: **investigación de antecedentes** y acompañamiento para el personal temporal; **acceso biométrico** en lugar de tarjetas magnéticas para evitar que se compartieran; **segregación de funciones** para que un técnico no pudiera apagar el CCTV sin activar alertas automáticas; y **cifrado de datos** junto con racks bajo llave, lo que habría impedido el acceso a la información y el robo de los servidores aunque los atacantes hubieran logrado entrar.